UNIVERSITI TEKNOLOGI MARA
MARKING SCHEME

COURSE	:	COMPUTER SECURITY
COURSE CODE	:	CSC662
EXAMINATION	:	OCTOBER 2026 (MOCK)
TIME	:	3 HOURS

MARKING SCHEME NOTES

1. This marking scheme accompanies the CSC662 mock paper (October 2026). Computed answers show working; theory answers are supported by lecture slides (not lecturer-marked) with a verbatim quote and slide citation.

2. Supported theory marking points quote the lecture decks; any unresolved slot would remain a visible placeholder.

3. Part A = 10 x (2 + 6); Part B = 2 x (5 + 5); total = 100 marks.

4. Computed: 1 slot(s). Supported theory: 23 slots. Placeholders: 0.
Questions and answers are for local study use only.

5. Near-copy rejection used all 35 past papers; style widening is recorded per slot.

FOR MARKERS' USE ONLY

This marking scheme consists of 15 printed pages

© Hak Cipta Universiti Teknologi MARA

CSC662 - MARKING SCHEME (MOCK OCTOBER 2026)

Labels: computed / supported by lecture slides (not lecturer-marked) / placeholder. No official marking scheme exists for the real CSC662 papers; this is generated for the mock.

Entailment labels: supported = the quote directly supports the marking point (or the point passed the stem-overlap gate without an LLM check); partly supported = the quote supports part of the point or is ambiguous; not supported = the quote does not support the point. Only 'not supported' points triggered regeneration.

Part A: 10 x (2 + 6) = 80 marks. Part B: 2 x (5 + 5) = 20 marks. Total: 100 marks. Slots: 1 computed, 23 supported by lecture slides, 0 placeholder.

Methods: computed answers use verified solvers. Theory answers are supported by lecture slides (not lecturer-marked). Each marking point carries a verbatim quote, a deck/slide/chunk citation and a term-overlap score; low overlap is flagged for human review. Sources are restricted to the slot topic's allowed decks, and a slide is not reused across questions where an alternative exists.

PART A - QUESTION 1

A1a - 2 marks - supported by lecture slides (not lecturer-marked)

Question:

List TWO (2) typical locations where IDS sensors are placed in a network-based IDS architecture.

Marking points:

No.	Point (1 mark)	Evidence quote	Source	Chunk	Stem overlap	Entailment
1	Sensors can be positioned just inside the firewall.	"Just inside the firewall"	062 - Intrusion Detection System, slide 7	062 - Intrusion Detection System::s07::1	0.50	supported (ste gate)
2	Sensors can be positioned on the DMZ.	"On the DMZ"	062 - Intrusion Detection System, slide 7	062 - Intrusion Detection System::s07::1	0.25 LOW	supported

Confidence: supported by lecture slides (not lecturer-marked) - each point carries a verbatim quote from the cited lecture slide.
Citations: 062 - Intrusion Detection System, slide 7

A1b - 6 marks - supported by lecture slides (not lecturer-marked)

Question:

Explain three preventive network security mechanisms that an organization can deploy to protect its network, and for each mechanism describe how it controls or secures network traffic.

Marking points:

No.	Point (1 mark)	Evidence quote	Source	Chunk	Stem overlap	Entailment
1	A firewall controls incoming and outgoing network traffic according to predetermined security policies.	"Control incoming and outgoing traffic on network with predetermined security policies."	061 - Network Security, slide 3	061 - Network Security::s03::1	0.80	supported (ste gate)
2	A proxy server improves data security and network performance by acting as a firewall and web filter, sharing network connections, and caching data.	"Proxy servers act as a firewall and web filter, provide shared network connections, and cache data to speed up common requests."	061 - Network Security, slide 3	061 - Network Security::s03::1	0.79	supported (ste gate)
3	Network segmentation creates boundaries between network segments whose computing assets share a common function, risk or role.	"Boundaries between network segments where computing assets within the segment have a common function, risk or role within an organization."	061 - Network Security, slide 3	061 - Network Security::s03::1	0.77	supported (ste gate)
4	A remote access VPN	"Provides remote and secure	061 - Network	061 - Network Security::s04::1	0.89	supported (ste gate)

© Hak Cipta Universiti Teknologi MARA

	gives individual hosts or clients remote and secure access to an organization's network.	access to an organization network to individual hosts or clients"	Security, slide 4			
5	Zero Trust Network Access restricts a user to only the access and permission required to fulfill the role.	"A user should only has access and permission that required to fulfill the role"	061 - Network Security, slide 4	061 - Network Security::s04::1	0.64	supported (ste gate)
6	IDS/IPS detect or prevent network security attacks such as brute force attacks, Denial-of-Service attacks and exploits of network vulnerabilities.	"To detect or prevent the network security attacks such as brute force attacks, Denial-of-Service attacks and exploits of network vulnerabilities."	061 - Network Security, slide 4	061 - Network Security::s04::1	0.86	supported (ste gate)

Confidence: supported by lecture slides (not lecturer-marked) - each point carries a verbatim quote from the cited lecture slide.
Citations: 061 - Network Security, slide 3; 061 - Network Security, slide 4

PART A - QUESTION 2

A2a - 2 marks - supported by lecture slides (not lecturer-marked)

Question:

Explain how a substitution cipher works and state what serves as its key.

Marking points:

No.	Point (1 mark)	Evidence quote	Source	Chunk	Stem overlap	Entailment
1	The cipher works by replacing each plaintext letter with a different letter, producing the ciphertext.	"In substitution ciphers, we replace the plain-text letters with other letters"	031 - Classical Cryptography, slide 4	031 - Classical Cryptography::s04::1	0.43 LOW	supported
2	The key is the rule that determines which substitutions are made.	"The substitution rule is the key"	031 - Classical Cryptography, slide 4	031 - Classical Cryptography::s04::1	0.50	supported (ste gate)

Confidence: supported by lecture slides (not lecturer-marked) - each point carries a verbatim quote from the cited lecture slide.
Citations: 031 - Classical Cryptography, slide 4

A2b - 6 marks - computed - matches lecture slide 15 (standard tableau)

Question:

Decrypt the following ciphertext using the Vigenere cipher with the key CIPHER. Use the standard 26 x 26 Vigenere tableau, writing the key over the message and repeating it as necessary.
UMRBVVNWVPREQE

Answer: SECURELOGINNOW

The 26 x 26 Vigenere tableau is printed in the question paper.

Working:

```
Standard 26 x 26 tableau, A=0; key repeated over the ciphertext.
Ciphertext: UMRBVVNWVPREQE
Key:        CIPHERCIPHERCI
Letter-by-letter: C - K mod 26 = P
  U (20) - C ( 2) = 18 -> S
  M (12) - I ( 8) =  4 -> E
  R (17) - P (15) =  2 -> C
  B ( 1) - H ( 7) = 20 -> U
  V (21) - E ( 4) = 17 -> R
  V (21) - R (17) =  4 -> E
  N (13) - C ( 2) = 11 -> L
  W (22) - I ( 8) = 14 -> O
  V (21) - P (15) =  6 -> G
  P (15) - H ( 7) =  8 -> I
  R (17) - E ( 4) = 13 -> N
```

© Hak Cipta Universiti Teknologi MARA

```
  E ( 4) - R (17) = 13 -> N
  Q (16) - C ( 2) = 14 -> O
  E ( 4) - I ( 8) = 22 -> W
Plaintext:  SECURELOGINNOW
```

Suggested marks: 1 mark for the key/table setup; 4 marks for the letter-by-letter working; 1 mark for the complete answer.

Confidence: computed - matches lecture slide 15 (standard tableau).

PART A - QUESTION 3

A3a - 2 marks - supported by lecture slides (not lecturer-marked)

Question:

List TWO (2) reasons why software is insecure, with particular reference to buffer overflows.

Marking points:

No.	Point (1 mark)	Evidence quote	Source	Chunk	Stem overlap	Entailment
1	Attackers can tamper with resources that are essential to program execution, such as the instruction pointer or function call addresses.	"Software insecurity stems from attacker's ability to modify system resources criticial for program execution, e.g. instruction pointer, function call addresses, interrupt addresses, etc."	051 - Software Security, slide 30	051 - Software Security::s30::1	0.69	supported (ste gate)
2	A major cause of software insecurity is the failure to validate user input.	"One of the key sources for software insecurity is failed validation of user input."	051 - Software Security, slide 30	051 - Software Security::s30::1	0.62	supported (ste gate)

Confidence: supported by lecture slides (not lecturer-marked) - each point carries a verbatim quote from the cited lecture slide.

Citations: 051 - Software Security, slide 30

A3b - 6 marks - supported by lecture slides (not lecturer-marked)

Question:

Windows is often described as having rich but complicated security. Explain six aspects of Windows security mechanisms, covering how subjects and credentials are handled, how resources are organised and controlled, and why this complexity can itself become a security problem.

Marking points:

No.	Point (1 mark)	Evidence quote	Source	Chunk	Stem overlap	Entailment
1	Windows subjects are processes and threads, i.e. active entities in OS primitives.	"Subjects are active entities in OS primitives."	041 - Windows Security, slide 11	041 - Windows Security::s11::1	0.57	supported (ste gate)
2	A subject's security credentials are kept in a token, which maps principals to subjects and may carry extra security attributes.	"Security credentials for a subject are stored in a token."	041 - Windows Security, slide 11	041 - Windows Security::s11::1	0.36 LOW	partly supporte
3	Active Directory, introduced in Windows 2000, is an LDAP-like directory service used to organise users, groups, credentials, resources and policies.	"Active directory introduced in Windows 2000 is an LDAP-like directory service for organization of system resources:"	041 - Windows Security, slide 6	041 - Windows Security::s06::1	0.64	supported (ste gate)
4	Windows provides complex mechanisms for user account and object management as well as access control.	"Windows systems contain complex security mechanisms for user account and object management as well as access control."	041 - Windows Security, slide 21	041 - Windows Security::s21::1	0.91	supported (ste gate)
5	Discretionary access control in Windows allows fine-grained control over heterogeneous entities both in the OS and in	"DACS enable fine-grained access control of heterogeneous entities in Windows itself as well as applications."	041 - Windows Security, slide 21	041 - Windows Security::s21::1	0.58	supported (ste gate)

© Hak Cipta Universiti Teknologi MARA

	applications.					
6	The very complexity of these mechanisms is a weakness, since misconfiguration and implementation bugs can cause serious security incidents.	"The complexity of Windows security mechanisms is also its enemy: misconfiguration as well as implementation bugs may lead to severe security incidents."	041 - Windows Security, slide 21	041 - Windows Security::s21::1	0.46 LOW	supported

Confidence: supported by lecture slides (not lecturer-marked) - each point carries a verbatim quote from the cited lecture slide.
Citations: 041 - Windows Security, slide 11; 041 - Windows Security, slide 21; 041 - Windows Security, slide 6

PART A - QUESTION 4

A4a - 2 marks - supported by lecture slides (not lecturer-marked)

Question:

State TWO (2) characteristics of Trojan horses as a type of malware.

Marking points:

No.	Point (1 mark)	Evidence quote	Source	Chunk	Stem overlap	Entailment
1	They disguise themselves as useful or benign software.	"They usually masquerade as helpful or harmless programs"	051 - Software Security, slide 12	051 - Software Security::s12::1	0.20 LOW	supported
2	They replicate themselves and steal information or damage the host system.	"trojans are malicious programs that replicate themselves and steal information or harm the host computer system"	051 - Software Security, slide 12	051 - Software Security::s12::1	0.75	supported (ste gate)

Confidence: supported by lecture slides (not lecturer-marked) - each point carries a verbatim quote from the cited lecture slide.
Citations: 051 - Software Security, slide 12

A4b - 6 marks - supported by lecture slides (not lecturer-marked)

Question:

Discuss six (6) malware attack techniques and propagation behaviours, explaining how each technique or behaviour enables the malware to spread or to act on an infected system.

Marking points:

No.	Point (1 mark)	Evidence quote	Source	Chunk	Stem overlap	Entailment
1	A rootkit hides malicious processes and software so that the infected machine stays under the attacker's remote control after a vulnerability is exploited.	"Rootkits are a type of malware that mask malicious processes and software in the infected systems to ensure privileged remote access."	051 - Software Security, slide 13	051 - Software Security::s13::1	0.40 LOW	supported
2	Spyware covertly gathers user credentials and activity, for example by logging keystrokes and recording visited sites.	"They steal user logins and passwords, document sites visited, log keystrokes and even redirect browsers to unwanted sites."	051 - Software Security, slide 13	051 - Software Security::s13::1	0.42 LOW	supported
3	A virus can be attached to an executable by appending the virus body to the host program.	"Append a virus body to a program"	051 - Software Security, slide 10	051 - Software Security::s10::1	0.50	supported (ste gate)
4	A virus can overwrite the program header so that execution is redirected to the virus code before returning to the original entry point.	"Over write a program header to switch the entry point to a virus"	051 - Software Security, slide 10	051 - Software Security::s10::1	0.39 LOW	supported
5	Early self-replicating code spread by	"Included in a boot sector of distributed software diskettes"	051 - Software Security, slide 7	051 - Software Security::s07::1	0.31 LOW	partly supporte

© Hak Cipta Universiti Teknologi MARA

	infecting the boot sector of distributed diskettes, as the Brain virus did.					
6	A worm can propagate over a network by exploiting a remote execution feature of a service, as the Morris worm did through sendmail.	"Used a debugging feature of sendmail (remote execution)"	051 - Software Security, slide 7	051 - Software Security::s07::1	0.23 LOW	partly supporte

Confidence: supported by lecture slides (not lecturer-marked) - each point carries a verbatim quote from the cited lecture slide.
Style confidence: LOW - exact examples n<3; widened via topic+marks (any command).
Citations: 051 - Software Security, slide 10; 051 - Software Security, slide 13; 051 - Software Security, slide 7

PART A - QUESTION 5

A5a - 2 marks - supported by lecture slides (not lecturer-marked)

Question:

Explain the difference between morals, ethics and laws as sources of guidance for professional conduct in computer security.

Marking points:

No.	Point (1 mark)	Evidence quote	Source	Chunk	Stem overlap	Entailment
1	Morals are described as traditions of belief concerning right and wrong conduct, forming the basis of social behaviour.	"Morals are traditions of belief about right and wrong conduct"	071 - Ethics and Computer Security, slide 5	071 - Ethics and Computer Security::s05::1	0.55	supported (ste gate)
2	Laws are formal rules of conduct imposed by a sovereign authority such as a government on its subjects or citizens.	"Laws are formal rules of conduct that a sovereign authority, such as a government, imposes on its subjects or citizens"	071 - Ethics and Computer Security, slide 5	071 - Ethics and Computer Security::s05::1	1.00	supported (ste gate)

Confidence: supported by lecture slides (not lecturer-marked) - each point carries a verbatim quote from the cited lecture slide.
Citations: 071 - Ethics and Computer Security, slide 5

A5b - 6 marks - supported by lecture slides (not lecturer-marked)

Question:

State six requirements that a professional code of ethics and conduct places on a computing professional, as illustrated by the ACM code and its professional conduct guidance.

Marking points:

No.	Point (1 mark)	Evidence quote	Source	Chunk	Stem overlap	Entailment
1	The professional must contribute to society and human well-being, recognising that all people are stakeholders in computing.	"Contribute to society and to human well-being, acknowledging that all people are stakeholders in computing."	071 - Ethics and Computer Security, slide 11	071 - Ethics and Computer Security::s11::1	0.73	supported (ste gate)
2	The professional must respect privacy and honour confidentiality in handling information.	"Respect privacy."	071 - Ethics and Computer Security, slide 11	071 - Ethics and Computer Security::s11::1	0.25 LOW	partly supporte
3	The professional must strive for high quality in both the processes and the products of professional work.	"Strive to achieve high quality in both the processes and products of professional work."	071 - Ethics and Computer Security, slide 12	071 - Ethics and Computer Security::s12::1	0.89	supported (ste gate)
4	The professional must know and respect the existing rules that	"Know and respect existing rules pertaining to professional work."	071 - Ethics and Computer Security, slide	071 - Ethics and Computer Security::s12::1	0.88	supported (ste gate)

© Hak Cipta Universiti Teknologi MARA

	pertain to professional work.		12			
5	The professional must perform work only in areas where he or she is competent.	"Perform work only in areas of competence."	071 - Ethics and Computer Security, slide 12	071 - Ethics and Computer Security::s12::1	0.56	supported (ste gate)
6	The professional must access computing and communication resources only when authorised or when compelled by the public good.	"Access computing and communication resources only when authorized or when compelled by the public good."	071 - Ethics and Computer Security, slide 12	071 - Ethics and Computer Security::s12::1	0.75	supported (ste gate)

Confidence: supported by lecture slides (not lecturer-marked) - each point carries a verbatim quote from the cited lecture slide.
Style confidence: LOW - exact examples n<3; widened via topic+marks (any command).
Citations: 071 - Ethics and Computer Security, slide 11; 071 - Ethics and Computer Security, slide 12

PART A - QUESTION 6

A6a - 2 marks - supported by lecture slides (not lecturer-marked)

Question:

Explain the two stages of the biometric authentication process and state what happens during each stage.

Marking points:

No.	Point (1 mark)	Evidence quote	Source	Chunk	Stem overlap	Entailment
1	The identification stage involves acquiring the biometric sample, creating the master characteristics and storing them.	"Identification Stage Acquisition Creation of Master characteristics Storage of Master characteristics"	072 - Biometrics and Authentication, slide 5	072 - Biometrics and Authentication::s05::1	0.30 LOW	supported
2	The authentication stage involves further acquisition, comparison against the stored data and a decision.	"Authentication Stage Acquisition(s) Comparison Decision"	072 - Biometrics and Authentication, slide 5	072 - Biometrics and Authentication::s05::1	0.50	supported (ste gate)

Confidence: supported by lecture slides (not lecturer-marked) - each point carries a verbatim quote from the cited lecture slide.
Citations: 072 - Biometrics and Authentication, slide 5

A6b - 6 marks - supported by lecture slides (not lecturer-marked)

Question:

Explain the categories of biometric applications and the characteristics of iris and fingerprint technologies, including the practical problems associated with fingerprint systems.

Marking points:

No.	Point (1 mark)	Evidence quote	Source	Chunk	Stem overlap	Entailment
1	Biometric applications are divided into two sectors, namely physiological and behavioural.	"Biometric applications available today are categorized into 2 sectors"	072 - Biometrics and Authentication, slide 4	072 - Biometrics and Authentication::s04::1	0.57	supported (ste gate)
2	The physiological category includes iris, fingerprints, hand, retinal and face recognition.	"Psychological: Iris, Fingerprints, Hand, Retinal and Face recognition"	072 - Biometrics and Authentication, slide 4	072 - Biometrics and Authentication::s04::1	0.67	supported (ste gate)
3	The behavioural category includes voice, typing pattern and signature.	"Behavioural: Voice, Typing pattern, Signature"	072 - Biometrics and Authentication, slide 4	072 - Biometrics and Authentication::s04::1	0.67	supported (ste gate)
4	Iris scanning works by scanning the unique pattern of the iris.	"Scans unique pattern of iris"	072 - Biometrics and Authentication,	072 - Biometrics and Authentication::s1	0.80	supported (ste gate)

© Hak Cipta Universiti Teknologi MARA

			slide 10	0::1		
5	Iris scanning requires no touch and overcomes the issues associated with retinal scanners.	"No touch required"	072 - Biometrics and Authentication, slide 10	072 - Biometrics and Authentication::s10::1	0.22 LOW	partly supporte
6	Fingerprint systems suffer from racial issues, dirt, grime and wounds, and placement of the finger.	"Racial issues"	072 - Biometrics and Authentication, slide 7	072 - Biometrics and Authentication::s07::1	0.20 LOW	partly supporte

Confidence: supported by lecture slides (not lecturer-marked) - each point carries a verbatim quote from the cited lecture slide.
Citations: 072 - Biometrics and Authentication, slide 10; 072 - Biometrics and Authentication, slide 4; 072 - Biometrics and Authentication, slide 7

PART A - QUESTION 7

A7a - 2 marks - supported by lecture slides (not lecturer-marked)

Question:

State TWO (2) formal security models that are classified as information flow models, and state the specific concern that the Chinese Wall model is designed to address.

Marking points:

No.	Point (1 mark)	Evidence quote	Source	Chunk	Stem overlap	Entailment
1	The Chinese Wall model is listed as an information flow model, identified by its detection of conflicts of interest.	"Chinese Wall model: identification of conflicts of interest"	024 - Formal Security Model, slide 5	024 - Formal Security Model::s05::1	0.62	supported (ste gate)
2	The Chinese Wall policy is specifically designed to address conflicts of interest faced by a consultant or contractor.	"Brewer and Nash's Chinese Wall Policy is designed to address a very specific concern: conflicts of interest by a consultant or contractor."	024 - Formal Security Model, slide 27	024 - Formal Security Model::s27::1	0.90	supported (ste gate)

Confidence: supported by lecture slides (not lecturer-marked) - each point carries a verbatim quote from the cited lecture slide.
Citations: 024 - Formal Security Model, slide 27; 024 - Formal Security Model, slide 5

A7b - 6 marks - supported by lecture slides (not lecturer-marked)

Question:

Describe the access control matrix, the access control list and the capability list as access control structures, giving one advantage and one disadvantage of the access control matrix and of the access control list, and stating what a capability list represents.

Marking points:

No.	Point (1 mark)	Evidence quote	Source	Chunk	Stem overlap	Entailment
1	The access control matrix is identified as a basic control structure for implementing access policies.	"ACM is a basic control structure."	023 - Access Control and Authorization, slide 8	023 - Access Control and Authorization::s08::1	0.43 LOW	supported
2	An advantage of the access control matrix is that it is clear to define and easy to verify.	"Advantages: clarity of definition easy to verify"	023 - Access Control and Authorization, slide 8	023 - Access Control and Authorization::s08::1	0.38 LOW	supported
3	A disadvantage of the access control matrix is poor scalability and poor handling of changes.	"Disadvantages: poor scalability poor handling of changes"	023 - Access Control and Authorization, slide 8	023 - Access Control and Authorization::s08::1	0.62	supported (ste gate)
4	An access control list is described as an object-	"ACL is an object-centered description of access rights:"	023 - Access Control and	023 - Access Control and	0.67	supported (ste gate)

© Hak Cipta Universiti Teknologi MARA

	centred description of access rights.		Authorization, slide 10	Authorization::s10::1		
5	An advantage of the access control list is easy access to an object's access rights and relative easiness of management using abstractions.	"Advantages: easy access to object access rights relative easiness of management using abstractions"	023 - Access Control and Authorization, slide 10	023 - Access Control and Authorization::s10::1	0.89	supported (ste gate)
6	A disadvantage of the access control list is a poor overview of access rights per subject, difficulty of revocation and difficulty of sharing.	"Disadvantages: poor overview of access rights per subject difficulty of revocation difficulty of sharing"	023 - Access Control and Authorization, slide 10	023 - Access Control and Authorization::s10::1	0.82	supported (ste gate)

Confidence: supported by lecture slides (not lecturer-marked) - each point carries a verbatim quote from the cited lecture slide.
Style confidence: LOW - exact examples n<3; widened via topic+marks (any command).
Citations: 023 - Access Control and Authorization, slide 10; 023 - Access Control and Authorization, slide 8

PART A - QUESTION 8

A8a - 2 marks - supported by lecture slides (not lecturer-marked)

Question:

Explain two ways in which a documented professional code of ethics shapes the ethical impact of technology practice, as described in the lecture.

Marking points:

No.	Point (1 mark)	Evidence quote	Source	Chunk	Stem overlap	Entailment
1	A code of ethics is a documented set of acceptable behaviours for a professional or social group, so it sets the standard against which the ethical impact of technology use is judged.	"Documented set of acceptable behaviors for professional or social groups."	071 - Ethics and Computer Security, slide 6	071 - Ethics and Computer Security::s06::1	0.43 LOW	partly supporte
2	Such a code adds clarity to the understanding of acceptable standards of behaviour, making the ethical expectations of technology work explicit.	"Adds clarity to the understanding of acceptable standards of behavior."	071 - Ethics and Computer Security, slide 8	071 - Ethics and Computer Security::s08::1	0.36 LOW	supported

Confidence: supported by lecture slides (not lecturer-marked) - each point carries a verbatim quote from the cited lecture slide.
Citations: 071 - Ethics and Computer Security, slide 6; 071 - Ethics and Computer Security, slide 8

A8b - 6 marks - supported by lecture slides (not lecturer-marked)

Question:

Refer to your answer in (a). Discuss how professional codes of ethics and the responsibilities of information specialists address privacy and organisational responsibility in computer security practice.

Marking points:

No.	Point (1 mark)	Evidence quote	Source	Chunk	Stem overlap	Entailment
1	Professional bodies such as the ACM publish a code of ethics and professional conduct that members are expected to follow.	"has a code of ethics and professional conduct."	071 - Ethics and Computer Security, slide 7	071 - Ethics and Computer Security::s07::1	0.36 LOW	partly supporte
2	The ACM has	"Association of Computing	071 - Ethics and	071 - Ethics and	0.78	supported (ste

© Hak Cipta Universiti Teknologi MARA

	established a code of ethics and professional conduct for computing practitioners.	Machinery ACM (founded 1947) has a code of ethics and professional conduct."	Computer Security, slide 7	Computer Security::s07::1		gate)
3	Merely describing moral and ethical dimensions of ICT is insufficient; organisations must actively address them.	"Simply describing may not be enough when discussing the moral and ethical dimensions of ICT"	071 - Ethics and Computer Security, slide 3	071 - Ethics and Computer Security::s03::1	0.36 LOW	partly supporte
4	Users in general carry definite responsibilities to act within ethical, moral and legal constraints.	"Users in general, and information specialists in particular, have definite responsibilities in terms of performing within ethical, moral, and legal constraints"	071 - Ethics and Computer Security, slide 3	071 - Ethics and Computer Security::s03::1	0.82	supported (ste gate)
5	Information specialists in particular bear responsibility for performing within ethical, moral and legal constraints when handling data.	"information specialists in particular, have definite responsibilities in terms of performing within ethical, moral, and legal constraints"	071 - Ethics and Computer Security, slide 3	071 - Ethics and Computer Security::s03::1	0.71	supported (ste gate)
6	Organisational responsibility for privacy is grounded in the ethical, moral and legal constraints that govern how ICT is used.	"performing within ethical, moral, and legal constraints"	071 - Ethics and Computer Security, slide 3	071 - Ethics and Computer Security::s03::1	0.40 LOW	partly supporte

Confidence: supported by lecture slides (not lecturer-marked) - each point carries a verbatim quote from the cited lecture slide.
Citations: 071 - Ethics and Computer Security, slide 3; 071 - Ethics and Computer Security, slide 7

PART A - QUESTION 9

A9a - 2 marks - supported by lecture slides (not lecturer-marked)

Question:

Explain how a disclosure threat and a usurpation threat each affect the confidentiality, integrity and availability of a system's assets.

Marking points:

No.	Point (1 mark)	Evidence quote	Source	Chunk	Stem overlap	Entailment
1	Disclosure is unauthorised access to information (e.g. snooping, sniffing, wiretapping) and is countered by confidentiality services, so it harms confidentiality.	"Disclosure - unauthorized access to information"	011 - Introduction to Computer Security, slide 10	011 - Introduction to Computer Security::s10::1	0.27 LOW	partly supporte
2	Usurpation is unauthorised control of part of a system (via modification, spoofing, delay, denial of service) and is countered by availability services, so it harms availability.	"Usurpation - unauthorized control of some part of a system"	011 - Introduction to Computer Security, slide 10	011 - Introduction to Computer Security::s10::1	0.29 LOW	partly supporte

Confidence: supported by lecture slides (not lecturer-marked) - each point carries a verbatim quote from the cited lecture slide.
Citations: 011 - Introduction to Computer Security, slide 10

A9b - 6 marks - supported by lecture slides (not lecturer-marked)

Question:

State six (6) characteristics of the Samy worm and the cross-site scripting (XSS) mechanism it exploited, explaining how each characteristic enabled the worm to spread or to act on an infected profile.

© Hak Cipta Universiti Teknologi MARA

Marking points:

No.	Point (1 mark)	Evidence quote	Source	Chunk	Stem overlap	Entailment
1	The worm injected JavaScript into a user profile by writing to document.body.innerHTML.	"Inject Javascript into a user profile using document.body.innerHTML"	052 - Web Security, slide 15	052 - Web Security::s15::1	0.70	supported (ste gate)
2	The worm obtained the list of a user's heroes by issuing a GET request on a user profile.	"Get the list of user's heros by using a GET on a user profile"	052 - Web Security, slide 15	052 - Web Security::s15::1	0.38 LOW	supported
3	The worm added Samy as a field by performing XML-HTTP on the addFriends page.	"Add Samy as a field by performing XML-HTTP on the addFriends page"	052 - Web Security, slide 15	052 - Web Security::s15::1	0.78	supported (ste gate)
4	Any user visiting an infected user's page had their profile infected with JavaScript and their friends list infected with Samy.	"Any user who visits an infected user's page will gets profile infected with Javascript and his friends list infected with Samy"	052 - Web Security, slide 15	052 - Web Security::s15::1	0.80	supported (ste gate)
5	The worm scaled to about 1,000,000 infected MySpace profiles.	"Eventually about 1,000,000 MySpace profiles were infected."	052 - Web Security, slide 15	052 - Web Security::s15::1	0.57	supported (ste gate)
6	Any web application that returns user input without filtering is a potential XSS vulnerability, allowing arbitrary JavaScript to execute in the user's browser.	"Any web application that returns user input without filtering is a potential XSS vulnerability!"	052 - Web Security, slide 13	052 - Web Security::s13::1	0.62	supported (ste gate)

Confidence: supported by lecture slides (not lecturer-marked) - each point carries a verbatim quote from the cited lecture slide.
Citations: 052 - Web Security, slide 13; 052 - Web Security, slide 15

PART A - QUESTION 10

A10a - 2 marks - supported by lecture slides (not lecturer-marked)

Question:

State TWO (2) detection outcomes that an intrusion detection system may produce when monitoring for attacks, and explain what each outcome indicates about the system's detection accuracy.

Marking points:

No.	Point (1 mark)	Evidence quote	Source	Chunk	Stem overlap	Entailment
1	A true positive occurs when the IDS correctly identifies an intrusion or attack.	"IDS correctly identify intrusions and attacks"	062 - Intrusion Detection System, slide 31	062 - Intrusion Detection System::s31::1	0.50	supported (ste gate)
2	A false positive is a legitimate activity that the IDS wrongly reports as malicious.	"Legitimate activity reported as malicious"	062 - Intrusion Detection System, slide 31	062 - Intrusion Detection System::s31::1	0.50	supported (ste gate)

Confidence: supported by lecture slides (not lecturer-marked) - each point carries a verbatim quote from the cited lecture slide.
Citations: 062 - Intrusion Detection System, slide 31

A10b - 6 marks - supported by lecture slides (not lecturer-marked)

Question:

Discuss six (6) threat classes and countermeasures relevant to computer security, explaining for each how the threat class endangers assets or how the countermeasure addresses it.

Marking points:

© Hak Cipta Universiti Teknologi MARA

No.	Point (1 mark)	Evidence quote	Source	Chunk	Stem overlap	Entailment
1	A threat is described as a potential violation of security rather than an actual one, so it represents a danger that may or may not materialise against an asset.	"A threat is a "potential" violation of security"	011 - Introduction to Computer Security, slide 9	011 - Introduction to Computer Security::s09::1	0.29 LOW	partly supporte
2	An attack is distinguished from a threat in that it is the actual violation of security, i.e. the realised exploitation rather than the potential danger.	"Attacks: The actual violation of security"	011 - Introduction to Computer Security, slide 9	011 - Introduction to Computer Security::s09::1	0.33 LOW	partly supporte
3	A threat is characterised as an object, person or other entity that represents a constant danger to an asset, which is the entity the countermeasures must guard against.	"Threat: object, person, or other entity representing a constant danger to an asset"	011 - Introduction to Computer Security, slide 28	011 - Introduction to Computer Security::s28::1	0.64	supported (ste gate)
4	Protection of assets is framed as encompassing prevention, detection and response techniques, giving the three countermeasure categories that can be applied against threats.	"Protection of assets encompasses prevention, detection and response techniques"	011 - Introduction to Computer Security, slide 28	011 - Introduction to Computer Security::s28::1	0.50	supported (ste gate)
5	Forces of nature are treated as among the most dangerous threat classes because they disrupt the storage, transmission and use of information.	"Forces of nature are among the most dangerous threats"	011 - Introduction to Computer Security, slide 13	011 - Introduction to Computer Security::s13::1	0.43 LOW	partly supporte
6	The countermeasure for natural threats is for organisations to implement controls that limit damage and to prepare contingency plans so that operations can continue.	"Organizations must implement controls to limit damage and prepare contingency plans for continued operations"	011 - Introduction to Computer Security, slide 13	011 - Introduction to Computer Security::s13::1	0.64	supported (ste gate)

Confidence: supported by lecture slides (not lecturer-marked) - each point carries a verbatim quote from the cited lecture slide.
Style confidence: LOW - exact examples n<3; widened via topic+marks (any command).
Citations: 011 - Introduction to Computer Security, slide 13; 011 - Introduction to Computer Security, slide 28; 011 - Introduction to Computer Security, slide 9

PART B - QUESTION 1

B1a - 5 marks - supported by lecture slides (not lecturer-marked)

Question:

State the role of the TPM in a trusted platform, and explain how a chain of trust is built from the hardware up to the running software. Your answer should identify the roots of trust involved and the mechanism used to record each stage.

Marking points:

No.	Point (1 mark)	Evidence quote	Source	Chunk	Stem overlap	Entailment
1	The TPM is described as a tamper-resistant	"Trusted Platform Module (TPM): a tamper-resistant hardware	073 - Trusted Computing,	073 - Trusted Computing::s06::	1.00	supported (ste gate)

© Hak Cipta Universiti Teknologi MARA

	hardware module mounted in the platform.	module mounted in a platform."	slide 6	1		
2	The TPM is responsible for measurement, protected storage, integrity reporting and policy enforcement.	"Responsible for: measurement, (protected) storage, (integrity) reporting and policy enforcement."	073 - Trusted Computing, slide 6	073 - Trusted Computing::s06::1	0.89	supported (ste gate)
3	In the chain of trust, each stage measures and validates the following stage.	"Each stage measures and validates the next one"	073 - Trusted Computing, slide 8	073 - Trusted Computing::s08::1	0.50	supported (ste gate)
4	The measurements taken at each stage are stored in Platform Configuration Registers (PCRs) on the TPM.	"Measurements go into Platform Configuration Registers (PCRs) on the TPM"	073 - Trusted Computing, slide 8	073 - Trusted Computing::s08::1	0.67	supported (ste gate)
5	The Root of Trust for Measurement is the component trusted to reliably measure and report to the Root of Trust for Reporting what software executes at the start of platform boot.	"Root of Trust for Measurement: the component that can be trusted to reliably measure and report to the Root of Trust for Reporting what software executes at the start of platform boot"	073 - Trusted Computing, slide 7	073 - Trusted Computing::s07::1	1.00	supported (ste gate)

Confidence: supported by lecture slides (not lecturer-marked) - each point carries a verbatim quote from the cited lecture slide.
Style confidence: LOW - exact examples n<3; widened via topic+marks (any command).
Citations: 073 - Trusted Computing, slide 6; 073 - Trusted Computing, slide 7; 073 - Trusted Computing, slide 8

B1b - 5 marks - supported by lecture slides (not lecturer-marked)

Question:

Discuss the components of the NGSCB architecture, explaining the role of the Nexus and the Nexus Computing Agent and how they work together to protect trusted software from the operating system.

Marking points:

No.	Point (1 mark)	Evidence quote	Source	Chunk	Stem overlap	Entailment
1	The Nexus acts as a security kernel that is authenticated during boot.	"Security kernel, authenticated on boot"	073 - Trusted Computing, slide 14	073 - Trusted Computing::s14::1	0.57	supported (ste gate)
2	The Nexus authenticates trusted programs and provides the application interface to the TPM.	"Authenticates trusted programs"	073 - Trusted Computing, slide 14	073 - Trusted Computing::s14::1	0.38 LOW	partly supporte
3	The Nexus does not trust the operating system.	"Does not trust OS"	073 - Trusted Computing, slide 14	073 - Trusted Computing::s14::1	0.50	supported (ste gate)
4	The Nexus Computing Agent is a trusted software component that runs in trusted mode and communicates with the Nexus.	"Runs in trusted mode that communicates with Nexus"	073 - Trusted Computing, slide 15	073 - Trusted Computing::s15::1	0.62	supported (ste gate)
5	The Nexus is a special kernel that isolates normal-mode and trusted-mode processes differently in memory.	"Isolate the process of normal mode and trusted mode differently in memory"	073 - Trusted Computing, slide 13	073 - Trusted Computing::s13::1	0.67	supported (ste gate)

Confidence: supported by lecture slides (not lecturer-marked) - each point carries a verbatim quote from the cited lecture slide.
Style confidence: LOW - exact examples n<3; widened via topic+marks (any command).

© Hak Cipta Universiti Teknologi MARA

Citations: 073 - Trusted Computing, slide 13; 073 - Trusted Computing, slide 14; 073 - Trusted Computing, slide 15

PART B - QUESTION 2

B2a - 5 marks - supported by lecture slides (not lecturer-marked)

Question:

Explain five password security controls that an administrator can apply to protect a system's password files and accounts, and state one password policy requirement for the root password.

Marking points:

No.	Point (1 mark)	Evidence quote	Source	Chunk	Stem overlap	Entailment
1	Apply access control to the password files so that only authorised users can read them.	"Access control applied to password files"	022 - Identification and Authentication, slide 12	022 - Identification and Authentication::s12::1	0.36 LOW	supported
2	De-activate an account after several failed login attempts.	"De-activation of accounts after multiple failed logins"	022 - Identification and Authentication, slide 12	022 - Identification and Authentication::s12::1	0.71	supported (ste gate)
3	Show the time of the user's last login so unusual activity can be noticed.	"Displaying the time of a last login"	022 - Identification and Authentication, slide 12	022 - Identification and Authentication::s12::1	0.33 LOW	partly supporte
4	Store the password in an encrypted form using a one-way hash function.	"Password is stored in an encrypted form using a one-way hash function:"	022 - Identification and Authentication, slide 8	022 - Identification and Authentication::s08::1	1.00	supported (ste gate)
5	For the root password, adopt a policy that it is never divulged over a telephone.	"never divulged over a telephone"	022 - Identification and Authentication, slide 12	022 - Identification and Authentication::s12::1	0.50	supported (ste gate)

Confidence: supported by lecture slides (not lecturer-marked) - each point carries a verbatim quote from the cited lecture slide.
Style confidence: LOW - exact examples n<3; widened via topic+marks (any command).
Citations: 022 - Identification and Authentication, slide 12; 022 - Identification and Authentication, slide 8

B2b - 5 marks - supported by lecture slides (not lecturer-marked)

Question:

A company wants to let staff reach many internal services after a single login, using Kerberos and other single sign-on approaches. Explain the motivation for single sign-on, the design criteria that Kerberos aims to satisfy, and the drawbacks of Kerberos that the company should consider.

Marking points:

No.	Point (1 mark)	Evidence quote	Source	Chunk	Stem overlap	Entailment
1	Single sign-on reduces the burden on users by cutting down the number of passwords they must remember.	"Reduce the need to memorize passwords"	022 - Identification and Authentication, slide 16	022 - Identification and Authentication::s16::1	0.17 LOW	supported
2	Single sign-on also lowers the time users spend typing passwords and the effort needed to maintain them.	"Reduce the time spent on typing passwords"	022 - Identification and Authentication, slide 16	022 - Identification and Authentication::s16::1	0.17 LOW	partly supporte
3	Kerberos is designed to resist eavesdropping by never sending passwords in clear text.	"Security against eavesdropping: no password transmission in clear text."	022 - Identification and Authentication, slide 18	022 - Identification and Authentication::s18::1	0.44 LOW	supported
4	Kerberos aims for transparency, so the user notices no	"Transparency: user is not aware of any authentication beyond an initial login."	022 - Identification and Authentication,	022 - Identification and Authentication::s18::1	0.67	supported (ste gate)

© Hak Cipta Universiti Teknologi MARA

	authentication beyond the initial login.		slide 18			
5	Kerberos is relatively complex to install and represents a single point of failure.	"Relatively complex in installation."	022 - Identification and Authentication, slide 23	022 - Identification and Authentication::s2 3::1	0.38 LOW	partly supporte

Confidence: supported by lecture slides (not lecturer-marked) - each point carries a verbatim quote from the cited lecture slide.
Style confidence: LOW - exact examples n<3; widened via topic+marks (any command).
Citations: 022 - Identification and Authentication, slide 16; 022 - Identification and Authentication, slide 18; 022 - Identification and Authentication, slide 23

End of marking scheme.

© Hak Cipta Universiti Teknologi MARA